

CCCS 453 – Security Risk Management and Governance

MODULE 6

Assignment #3: PCI DSS v4.0.1

Al Labade, Ayman

1. Patching Frequency

PCI DSS v4.0.1 specifies that systems in scope must be protected from known vulnerabilities by installing security patches and updates within defined time frames. Patches or updates for critical vulnerabilities must be installed within 30 days (one month) of their release, while all other applicable patches must be installed within an appropriate time frame based on the organization's risk-ranking process, as defined in **PCI DSS requirement 6.3.3**.

2. Password complexity/strength

For password complexity and strength, PCI DSS v4.0.1 requires passwords or passphrases used for authentication to be at least 12 characters long, or at least 8 characters for legacy systems that cannot support 12 characters. These passwords must also include both alphabetic and numeric characters to meet the minimum complexity level, as stated in **PCI DSS requirement 8.3.6**.

3. Password change frequency

Passwords for systems and application accounts must be changed at least every 90 days, or more frequently if required by a targeted risk analysis, according to **PCI DSS requirement 8.6.3**. This helps reduce the risk that exposed or guessed passwords remain valid for too long.

4. Minimal log attributes

Audit logs for each auditable event must capture sufficient detail, including user identification, type of event, date and time, whether the event was a success or failure, the origin of the event, and the identity of the affected data or system component, as defined in **PCI DSS requirement 10.2.2**.

5. Audit trail retention

Organizations must retain audit log history for at least 12 months, with the most recent three months of logs immediately available for analysis, to support effective incident investigation as required by **PCI DSS requirement 10.5.1**.

Overall, these PCI DSS v4.0.1 requirements work together to strengthen how organizations protect cardholder data by enforcing secure patching, strong authentication, detailed logging, and sufficient log retention for investigations.